

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 1 頁，共 15 頁

單選題 50 題 (佔 100%)

D	1. 關於 ISO 27001 資訊安全管理系統描述，下列何項正確？ (A) 對資訊安全管理之實作，所有組織皆須依照 ISO 27002 實施 (B) ISO 27001 標準只適用於組織對內部人員的要求事項 (C) ISO 27001 標準描述呈現之順序，即為對資訊安全管理系統實作之順序 (D) 組織可導入許多國際標準管理系統，ISO 27001 主要針對在資訊安全
C	2. ISO 27001 資訊安全管理系統中，管理審查會議是屬於 PDCA 中的何項程序？ (A) 規畫 (Plan) (B) 執行 (Do) (C) 檢核 (Check) (D) 行動 (Act)
B	3. 因應客戶的要求，貴公司擬導入個人資料保護的相關標準，因兩個月前您才幫公司完成 ISO 27001:2022 轉版驗證；為達最佳效益，試問您會建議公司導入下列何項認證標準？ (A) ISO 10012 (B) ISO 27701 (C) ISO 27017 (D) ISO 27018
A	4. 在 ISO 27001：2022 的改版重點中，下列何者「不」是本次新增的內容？ (A) 設備汰除或重新使用之保全 (B) 威脅情資 (C) 使用雲端服務之資訊安全 (D) 組態管理

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 2 頁，共 15 頁

C	5. 在 ISMS 管理審查會議中，下列何者「不」是必要考量的事項？ (A) 過往管理審查之決議的處理狀態 (B) 關注方之回饋 (C) 外部利害關係人的參與 (D) 風險評鑑結果及風險處理計畫之狀態
D	6. 根據政府頒佈之資通安全事件通報及應變辦法，受資通安全管理法管制之機關（以下簡稱：受管制機關）進行資通安全事件應變及通報之敘述，下列何者有誤？ (A) 受管制機關知悉資通安全事件後，應於一小時內依主管機關指定之方式及對象，進行資通安全事件之通報 (B) 主管機關應於受管制機關完成資通安全事件之通報後，通報為第一級或第二級資通安全事件者，於接獲後八小時內完成資通安全事件等級之審核 (C) 主管機關應於受管制機關完成資通安全事件之通報後，通報為第三級或第四級資通安全事件者，於接獲後二小時內完成資通安全事件等級之審核 (D) 受管制機關知悉資通安全事件後，第三級或第四級資通安全事件，應於知悉該事件後七十二小時內完成損害控制或復原作業，並依主管機關指定之方式及對象辦理通知事宜

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 3 頁，共 15 頁

A	7. 如附圖所示。王小明在直轄市政府擔任資安專責人員，為將次年度資訊安全相關演練事宜（如社交工程演練、資通安全事件通報及應變演練）規劃結果陳報主管核准，請問，如附圖公文擬稿文字中的 A/B/C，所代表的項目為何，將可達到合規遵法最基本要求？ 主旨：(略) 說明： 一、依據《A》第 8 條第 2 項規定，本單位應辦理如社交工程演練、資通安全事件通報及應變演練等資安作業。 二、擬執行次數： （一）社交工程演練：預計於明年辦理 B 次。 （二）資通安全事件通報及應變演練：預計於明年辦理 C 次。 …（以下略） (A) 資通安全事件通報及應變辦法／2／1 (B) 資通安全責任等級分級辦法／2／1 (C) 公務機關所屬人員資通安全事項獎懲辦法／1／2 (D) 資通安全情資分享辦法／1／2
A	8. 台灣某國際商業銀行為一家 Visa、MasterCard 等信用卡發卡銀行，為了確保持卡人的信用卡資訊及付款資料，能在安全可信的環境中處理、傳輸或儲存，進而建置國際公認且專屬信用卡資訊處理保護的管理制度。請問此制度的最有可能為下列何項？ (A) PCI DSS (B) GDPR (C) HIPPA (D) Sarbanes-Oxley
D	9. 有關資通安全演練作業類型的規定，是明定於《資通安全管理法》的哪一項子法？ (A) 資通安全責任等級分級辦法 (B) 資通安全管理法施行細則 (C) 資通安全情資分享辦法 (D) 資通安全事件通報及應變辦法

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 4 頁，共 15 頁

B	10. 關於 ISO 27001:2022 標準中，要求文件化資訊的項目，下列哪一項錯誤？ (A) 資訊安全政策 (B) 最高管理階層的領導作為 (C) 資訊安全管理系統（ISMS）範圍 (D) 資訊安全目標
D	11. 下列何項與 GDPR（General Data Protection Regulation）規範的要求不符？ (A) GDPR 為歐盟一般資料保護法規 (B) 要求持有歐盟個人可識別資訊的組織，需實施安全控制措施以防止個人資料遺失 (C) 任何使用與歐盟居民相關資訊的組織都須遵循 (D) 僅規定位於歐盟地區的公司組織須遵守
C	12. 請問下列何項屬於個人資料保護法第六條所規範，除符合特定情形，不得蒐集、處理或利用之個人資料？ (A) 姓名 (B) 職業 (C) 健康檢查的報告內容 (D) 國民身分證統一編號
C	13. 請問以下何項「不」是著作權法所述之「著作權之標的」？ (A) 攝影著作 (B) 電腦程式著作 (C) 單純為傳達事實之新聞報導所作成之語文著作 (D) 圖形著作
B	14. 關於資訊資產管理中資產盤點的敘述，下列何項正確？ (A) 資產盤點僅是採購資產時進行之活動 (B) 資產盤點應該定期進行 (C) 資產盤點僅需盤點數位資產 (D) 資產盤點僅需盤點軟體資產

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 5 頁，共 15 頁

C	15. 某組織在進行資訊資產分類及保護的過程中，會明定不同角色人員以確保其功能與職責，一般常見為稱擁有者（Owner）、保管者（Custodian）、使用者（User）、稽核員（Auditor），參考 CNS 27002:2023 對資產擁有者的相關職掌項目定義後，請問下列何項最可能「非」屬擁有者必要負責之工作事項？ (A) 確保已對系統、資訊及其他相關聯資產完成盤點 (B) 確保將資訊及其他相關聯資產適切分類分級並保護之 (C) 確保資產以最低成本進行採購 (D) 確保資訊及其他相關聯資產於刪除或棄置時，以安全方式處理
B	16. 下列何項「不」是 ISO 27001 對於資訊之分類分級的要求？ (A) 依組織之資訊安全需要 (B) 依資安管理系統最高管理者（資安官）之偏好 (C) 考量分類分級方案中對機密性、完整性及可用性之要求事項 (D) 考量相關關注方要求事項
C	17. 如附圖所示。企業為確保資訊資產能獲得適切保護而依照 CNS 27001:2023 建置資安管理制度，並瞭解 CNS 27002:2023 所規定的資訊資產相關控制措施主要有附圖中的 4 項。請問下列的執行順序何者較為適宜？ 1. 資訊之分類分級 2. 編製資訊及其他相關聯資產之清冊 3. 資訊的處置（如傳送、歸還等） 4. 資訊之標示 (A) 3、2、4、1 (B) 4、1、3、2 (C) 2、1、4、3 (D) 3、4、1、2

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 6 頁，共 15 頁

B	18. 行政院發布的《文書處理手冊》所規定「公文紙格式」中，有一個欄位稱為「密等及解密條件或保密期限」。請問，依據其特性並對照 CNS 27002:2023，較屬於下列何項資訊資產管理機制的管控措施？ (A) 5.11 資產之歸還 (B) 5.13 資訊之標示 (C) 5.9 資訊及其他相關聯資產之造冊 (D) 5.10 可接受使用資訊及其他相關聯資產
A	19. 有關 NIST 定義資料生命週期的資料運用狀況，依方式和時間點不同而有不同狀態。請問，當資料在非永久性儲存硬體、應用軟體等情境時，如 RAM、CPU、DLP Agent，可將其歸類於下列何狀態？ (A) Data in use (B) Data on the fly (C) Data in motion (D) Data at rest
C	20. 關於紙本類之資訊資產保護原則，下列敘述何者最「不」正確？ (A) 內部使用級之紙本類資訊資產，於保管人員暫時離開座位時，不得置於開放空間處 (B) 內部使用級之紙本類資訊資產，於保管人員長時間離開座位時，應放置於上鎖空間或上鎖櫃並隨時上鎖 (C) 密級之紙本類資訊資產，於保管人員暫時離開座位時，得置於開放空間處 (D) 密級之紙本類資訊資產，於保管人員進出上鎖空間或借用上鎖櫃之鑰匙時應作成紀錄

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 7 頁，共 15 頁

C	21. 風險評鑑發現，公司內部機密外洩的風險過大；資訊單位導入資料外洩防護（DLP）系統做為因應措施，請問資訊單位的做法是屬於下列何種風險回應？ (A) 風險保留（Risk Retention） (B) 風險避免（Risk Avoidance） (C) 風險降低（Risk Reduction） (D) 風險轉移（Risk Transfer）
A	22. 下列何者「不」是風險位階矩陣中風險發生機率的三個等級之一？ (A) 無 (B) 低 (C) 中 (D) 高
D	23. 關於風險管理循環執行順序的描述，下列何者較為正確？ (A) 風險識別 > 風險處理 > 風險分析 > 風險評估 (B) 風險評估 > 風險識別 > 風險處理 > 風險分析 (C) 風險處理 > 風險識別 > 風險分析 > 風險評估 (D) 風險識別 > 風險分析 > 風險評估 > 風險處理
C	24. 系統在完成測試並確認了變更作業後，就得以開始進行「系統轉換」，以更換至另一個系統或軟體版本，目前實務上常見的「系統轉換」方法有下列四種：並行式（Parallel）轉換、階段式（Phased）轉換、一次性（Abrupt）轉換、引導式（Pilot）轉換。請問，下列何項系統轉換方式的轉換作業風險是最大的？ (A) 並行式（Parallel） (B) 階段式（Phased） (C) 一次性（Abrupt） (D) 引導式（Pilot）

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 8 頁，共 15 頁

D	25. CNS 31010 提供系統化風險評鑑方法選擇及應用的指引文件，摘列適用於各個層級的風險評鑑方法，其中有一項稱之為「企業衝擊分析」(BIA)。請問運用此項方法的最大好處為下列何項？ (A) 無需再執行風險分析作業 (B) 無需定期進行重新評估，不會所受到影響或衝擊不會改變風險值 (C) 僅使用定性評估方式就可以完成 (D) 可以增進企業業務持續運作的意識
D	26. 當密碼作為鑑別資訊時，依最佳實務作法之建議，選用高強度密碼，下列何者較「不」屬於高強度密碼？ (A) 密碼非依辭典字詞或其組合 (B) 使用易於記憶之通行片語，並須包含文數字及特殊字元。 (C) 要求密碼符合一定長度 (D) 密碼可依他人可使用個人之相關資訊，例如姓名、電話號碼、出生日期
D	27. 對於 SSO (Single Sign On) 的描述，下列何者較「不」適切？ (A) 一次登入可以對應多個系統帳號 (B) 每個系統都有自己的帳號 (C) 當系統、API 修改或系統異常，信任關係即失效 (D) 可記憶密碼

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 9 頁，共 15 頁

C	28. 在 ISO 27001 的遠距工作管理規範下，若一個組織決定完全禁止遠距工作，並在其聲明中將該控制措施標註為「不適用」，下列何者描述最能與該聲明相符？ (A) 確保現階段組織內無員工進行遠距工作，並在文件中說明該控制項不適用 (B) 確認組織未來可能的業務需求和風險變化，以便根據需要靈活調整遠距工作政策 (C) 確認並記錄在所有情況下（包括應急或特殊情況）都禁止遠距工作，並提供相應的證據 (D) 定期審查和更新遠距工作政策，即使目前遠距工作被禁止，仍需為未來需求保留調整空間
B	29. 採用多因子身分認證機制，主要目的是避免什麼攻擊方式，以下描述何者較「不」適切？ (A) 避免生物特徵被竊取或挾持 (B) 避免個資拼圖 (C) 避免遭受鍵盤側錄 (D) 避免單一機制被暴力破解
A	30. 下列何項「不」是資料庫的資料加密方式？ (A) 資料遮罩（Data Masking） (B) 透明資料加密（Transparent Data Encryption，TDE） (C) 資料欄位加密 (D) 資料庫檔案加密

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：I11 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 10 頁，共 15 頁

B	31. 數位憑證 (Digital Certificate) 是在網際網路上識別人員和資源的電子檔案，能夠讓兩個實體之間能夠進行安全、機密的通訊。請問下列何項「不」是數位憑證的正確描述？ (A) 使用在伺服器上的數位憑證又稱為「伺服器憑證」、HTTPS/SSL 憑證，SSL 憑證是在網頁伺服器（主機）與網頁瀏覽器（客戶端）之間建立一個密碼連結的標準規範 (B) 一般網頁用的 SSL 憑證檔案中包含公鑰資訊、擁有者身分資訊、數位憑證發行者、憑證有效到期日，但是不會出現發行憑證日期 (C) 大部分的瀏覽器會在網址列裡顯示一個鎖的圖示或是其他識別方式，如果要了解 SSL 憑證的細節，只要點擊鎖的圖示即可 (D) 憑證用途非常廣泛，像是自然人憑證、工商憑證、健保卡等都是屬於數位憑證的用途，幾乎身分與機構識別都有利用到此技術
D	32. 在存取控制或零信任中，常提到 AAA 原則或 3A 管制、3A 框架，下列何項「不」是其中之一？ (A) 驗證身份 (Authentication) (B) 檢查授權 (Authorization) (C) 記錄行為 (Accounting) (D) 帳號管理 (Account Management)
C	33. 請問下列何種生物特徵 (Biometrics) 類型的效期最短？ (A) 指紋識別 (B) 虹膜識別 (C) 聲紋識別 (D) 掌形識別

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 11 頁，共 15 頁

D	34. 當使用者主張自己的身分後，系統應該確認使用者是否為所宣稱的合法身分擁有者，這個證明使用者身分的過程就被稱為「身分驗證」(Authentication)，常見的身分驗證方法，下列敘述何者最「不」適切？ (A) 所知之事 (Something you Know)：密碼、PIN Code、安全問答等 (B) 所有之物 (Something you Have)：Token、USB 金鑰、智慧晶片卡 (Smart Cards) (C) 所具之形 (Something you Are)：生物特徵 (指紋、虹膜、聲紋等) (D) 所用之物 (Something you Use)：透過使用者所使用的裝置，例如電腦、瀏覽器類型或作業系統來確認身分
B	35. 信任運算基礎 (Trusted Computing Base, TCB) 是指系統內所有對安全性至關重要的硬體、軟體與控制機制，這些組件的正確性與完整性決定了系統的整體安全性。關於 TCB 的設計原則，下列敘述何者最「不」適切？ (A) 完整性保護 (Integrity Protection)：TCB 內的關鍵組件應該受到完整性驗證 (如 TPM、數位簽章)，確保未被竄改 (B) 高安全性 (High Security)：將所有安全相關應用程式都納入 TCB (C) 最小權限原則 (Least Privilege)：TCB 內的組件應只擁有執行必要功能的最低權限，避免濫用 (D) 最小 TCB (Minimization)：TCB 應該儘可能小，以降低攻擊面並提升可信度

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 12 頁，共 15 頁

D	36. 請問數位簽章的主要作用為下列何項？ (A) 加密資料 (B) 解密資料 (C) 生成隨機數 (D) 驗證資料的完整性與來源
C	37. 假設手上有一組金鑰對，其中金鑰 A 能將明文 x 變成密文 y；金鑰 B 能將密文 y 變成明文 x，這二把金鑰非屬同一把金鑰，且當加密演算法所用的運算函數為指數運算 (mod) 時，請問所用的加密演算法較有可能是下列哪一項？ (A) ECC (B) AES (C) RSA (D) DES
D	38. 對達成使用密碼技術的資訊安全目標，下列何項描述有誤？ (A) 機密性：使用資訊加密可以保護敏感資訊 (B) 完整性：使用數位簽章加密機制於檔案，以確保資料完整性傳遞 (C) 不可否認性：對資料使用密碼技術，以提供事故發生時存取相關的證據 (D) 可用性：使用密碼技術以鑑別使用者對資源存取異動時的證據
D	39. 關於使用者管理密碼之方式，下列敘述何者較「不」適當？ (A) 使用強密碼（複雜性密碼） (B) 定期更改密碼 (C) 避免多個帳號使用相同密碼 (D) 使用自動登入儲存密碼，以避免忘記密碼

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 13 頁，共 15 頁

B	40. 關於權限管理，下列敘述何者較「不」適當？ (A) 使用者如有需求，應依組職規定，向權責主管提出權限申請 (B) 權責主管在收到使用者權限申請，應依使用者職務需求，核准其工作所需最大權限 (C) 系統管理人員不得擅自執行未經核可之權限異動 (D) 如有系統遠端維護之需求，應限制必須為核可的遠端連線來源
A	41. 依據「資通安全事件通報及應變辦法」所訂定的資通安全事件之嚴重等級共有四類，如某一特定非公務機關判別某一個非核心資通系統之資訊遭受輕微竄改，則該事件之嚴重等級為下列哪一級？ (A) 第一級 (B) 第二級 (C) 第三級 (D) 第四級
C	42. 在資安事故管理中，下列何項活動應於事故發生後立即進行？ (A) 計畫的定期審查 (B) 員工教育訓練 (C) 影響範圍評估 (D) 事件記錄歸檔
D	43. 下列何項較「不」屬於資安事故數位證據的要求？ (A) 記錄完整且未遭竄改 (B) 與原件相同的電子證據複本 (C) 所涉資訊系統於記錄時應有正確時間戳記 (D) 於存放證據之文件袋加以彌封

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 14 頁，共 15 頁

B	44. 美國、歐盟及我國皆有針對該國家的企業組織、關鍵基礎設施等機構，規範於發現或發生資安事件時應辦理的相關事項，其中有關重大事件應通報主管機關的時效規定，請問，下列何者的時間為「最短」？ (A) 我國《資通安全事件通報及應變辦法》 (B) 我國《證券期貨市場資通安全事件通報應變作業注意事項》 (C) 歐盟《The Digital Operational Resilience Act》 (D) 美國《Cyber Incident Reporting for Critical Infrastructure Act》
C	45. 某公司發現內部員工涉嫌資料竊取。下列何項措施最能確保調查的合法性？ (A) 立即沒收該員工個人的電腦與手機，並進行全面資料掃描 (B) 在未告知員工的情況下，秘密監控其網路活動與通訊紀錄 (C) 遵循法律程序，取得必要的授權，並保護員工的合法權益 (D) 公司內部成立調查小組，並在未經員工同意下，對其工作區域進行隱蔽式監視
B	46. 關於審查資訊安全營運持續流程的敘述，下列何者較為正確？ (A) 當有新的或重大內、外部議題時，與資訊安全相關的營運持續可於每年定期審查時，再一併納入考量 (B) 組織內部需要安排時程測試資訊安全持續計劃，且須確認與資訊安全持續目標是否一致的結果 (C) 需要納入資訊安全營運持續的資訊系統，視資訊部門可用資源為優先考量 (D) 當營運持續計畫演練完成後，若有需要後續程序調整的內容，可於下次安排演練後再予以調整

114 年度第 1 次 資訊安全工程師能力鑑定 初級試題

科目：III 資訊安全管理概論

考試日期：114 年 5 月 17 日

第 15 頁，共 15 頁

B	47. 備援計劃的主要目的，下列何者描述較為適切？ (A) 提高系統運作性能 (B) 確保業務持續 (C) 減少員工工作負荷 (D) 增加公司營收
A	48. 在規劃緊急災難復原方法時，下列何項較屬優先的重要核心考慮因素？ (A) 業務流程的關鍵性和對影響的容忍度 (B) 存取權限 (C) 資料類型 (D) 資料容量
B	49. 當組織設定重要系統災害復原之 RTO 為 16 小時、RPO 為 3 天時，下列何項的備份週期係屬最小成本且能符合組織要求之規劃？ (A) 12 小時 (B) 2 天 (C) 5 天 (D) 每週備份
C	50. 某公司遭受勒索軟體攻擊，導致主要系統資料被加密，業務運作受到嚴重影響。在這種情況下，下列何項措施對於確保營運持續性最為關鍵？ (A) 立即支付贖金，以恢復系統運作 (B) 找技術專家破解加密，以恢復資料 (C) 使用未受感染的備份資料，恢復系統運作 (D) 關閉所有系統，暫停服務運作